COMPTIA SECURITY+ SY0-701 | DOMAIN 2 · THREATS, VULNERABILITIES, AND MITIGATIONS (22%)

# Security+ 2.3 · Cloud-specific Vulnerabilities

Mestre CyberSec · **Lesson 2.3 — Cloud-specific Vulnerabilities** (4:06) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

**Executive Lesson Summary:** Ataques da nuvem: DoS com FATURA (gera custo alto — o atacante não derruba o serviço, só deixa caro); authentication bypass (API aberta/exploit); directory traversal (acessar arquivo fora do permitido). O maior risco NUVEM: MISCONFIGURAÇÃO (bucket aberto, IAM permissivo). Respons

## 💡 Key Exam Highlights & Critical Concepts

- Bucket S3 aberto = o vazamento nº1 de cloud
- Respons. compartilhada: provider = DA nuvem; cliente = NA nuvem
- Defesa: CSPM (checa config), IAM com menor privilégio

## 🎯 Exam Tips & Typical CompTIA Scenarios

- 'misconfigured bucket exposes data' = cloud misconfig (a falha nº1)
- 'client is responsible for securing data IN the cloud' = shared responsibility

## 🚨 Beyond the Video: Official Exam Concepts, Protocols & Traps (Section 2.3 — Cloud-specific Vulnerabilities)

**Why is this advanced coverage required for SY0-701?:** Video lectures provide foundational concepts, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

**• Cloud Misconfiguration (N/A)**

Improperly configured cloud resources (e.g., open S3 buckets, permissive security groups) that expose sensitive data. Identified by CompTIA as the #1 cloud security risk.

⚠ ***Exam Trap:*** *Trigger: 'misconfigured bucket exposes data' or 'publicly accessible storage'. Always choose cloud misconfiguration over more exotic attacks — it is the MOST common cloud breach vector on the exam.*

**• Shared Responsibility Model (N/A)**

Cloud security model where the provider is responsible for security OF the cloud (infrastructure, hosts, physical), while the customer is responsible for security IN the cloud (data, access, configurations).

⚠ ***Exam Trap:*** *Trigger phrase: 'Who secures the customer's data?' → Answer is ALWAYS the customer. Remember: 'OF the cloud = Provider; IN the cloud = Customer'. A classic exam trap.*

**• Cloud Security Posture Management (CSPM)**

A tool/automation that continuously assesses cloud configurations against best practices (e.g., CIS benchmarks) to detect misconfigurations, compliance violations, and drift.

⚠ ***Exam Trap:*** *Question cue: 'Which tool detects misconfigured cloud assets automatically?' → CSPM. Distinguish from CASB (user-facing DLP) and CWPP (workload protection).*

**• Billing/Financial Denial of Service (BDoS / DoS)**

A cloud-specific DoS variant that exhausts the victim's cloud budget by generating massive resource consumption (API calls, storage, bandwidth) rather than crashing the service.

⚠ ***Exam Trap:*** *Trigger: 'attacker drives up cloud costs' or 'service still works but bill is huge'. This is THE cloud-specific DoS scenario — don't confuse with traditional volumetric DDoS.*

**• Identity and Access Management (IAM)**

Framework that manages digital identities and their permissions to cloud resources. CompTIA emphasizes least privilege and role-based access control (RBAC) as core principles.

⚠️ ***Exam Trap:*** *Trigger: 'overly permissive access' or 'user has more rights than needed' → IAM misconfiguration. Pair with Least Privilege Principle — always the answer for access control questions.*

**• Directory Traversal (N/A)**

An attack using sequences such as '../' to escape the intended directory and access unauthorized files on a server or cloud storage object.

⚠️ ***Exam Trap:*** *Trigger: '../etc/passwd' or 'attacker accesses files outside the web root'. In cloud context, this targets object keys and blob storage paths — input validation is the key mitigation.*

**• Authentication Bypass (N/A)**

An attack exploiting flaws in API endpoints or authentication logic (e.g., broken token validation, exposed keys) to gain unauthorized access without valid credentials.

⚠️ ***Exam Trap:*** *Trigger: 'attacker accesses cloud resource without password' or 'exposed API key in public repo'. Look for API gateway misconfiguration or hardcoded credentials as the root cause.*

**• Simple Storage Service (Public Bucket) (S3)**

AWS object storage service frequently involved in major data breaches when buckets are configured with public access. The canonical example of cloud misconfiguration on the exam.

⚠️ ***Exam Trap:*** *Trigger: 'open S3 bucket' or 'publicly readable object storage' → Cloud Misconfiguration. Know the difference between S3 (object) vs EBS (block) vs EFS (file) — S3 is the one that gets breached via public ACL.*

## 🏛️ Conceptual Deep Dive, Real-World Analogies & GRC Analysis

### 📌 S3 (Objetos) vs. EBS (Blocos) vs. EFS (Arquivos)

🏠 **Real-World Analogy:** O S3 é como um depósito público de caixas postais acessível pela calçada, onde cada pacote ganha uma URL web pública. Já o EBS é um HD interno parafusado na placa-mãe de um único PC, e o EFS é a pasta compartilhada da rede local do escritório.

🔍 **Root Cause & Background:** O S3 foi desenhado para hospedar arquivos web estáticos acessíveis mundialmente. Se a política do bucket ou ACL for configurada com acesso público acidental, os arquivos confidenciais ficam abertos para qualquer internauta.

🛡️ **GRC Auditor Perspective:** Verificar se o recurso S3 Block Public Access está ativado em nível de conta inteira e auditar políticas com ferramentas de CSPM.

⚠️ **How CompTIA Tests This:** Trigger: "open S3 bucket" ou "publicly accessible storage". Resposta: Cloud Misconfiguration (o risco nº1 da nuvem na CompTIA).

### 📌 A Trindade de Nuvem: CSPM vs. CASB vs. CWPP

🏠 **Real-World Analogy:** O CSPM é o auditor predial que fiscaliza as configurações e travas do edifício 24h por dia; o CASB é a alfândega/guarda de fronteira na guarita que inspeciona o que os funcionários levam e trazem entre seus notebooks e a nuvem externa; e o CWPP é o segurança armado dentro de cada sala (servidor/contêiner) protegendo o sistema operacional contra malware.

🔍 **Root Cause & Background:** Ambientes de nuvem são dinâmicos e sofrem desvios de configuração (drift). Sem ferramentas automáticas contínuas, desconfigurações passam despercebidas.

🛡️ **GRC Auditor Perspective:** Implementar CSPM para monitoramento contínuo de conformidade contra CIS Benchmarks; CASB para DLP de SaaS; CWPP para segurança de runtime em workloads.

⚠️ **How CompTIA Tests This:** Trigger: "detects misconfigured cloud assets automatically" -> CSPM. "User DLP on SaaS" -> CASB. "Workload/host protection" -> CWPP.

### 📌 Ataques BDoS / EDoS (Billing / Economic Denial of Sustainability)

🏠 **Real-World Analogy:** Não tenta derrubar o restaurante; o atacante apenas pede 10.000 pratos caros usando entrega automática. O restaurante continua funcionando a todo vapor, mas no fim do mês a conta da distribuidora vem impagável e quebra o negócio.

🔍 **Root Cause & Background:** O auto-scaling da nuvem provisiona instâncias e recursos cobrados por consumo (metered) sob demanda. Sem limites máximos, requisições pesadas esgotam o orçamento financeiro.

🛡️ **GRC Auditor Perspective:** Estabelecer Resource Quotas e tetos máximos de auto-scaling (scaling caps), rate limiting na borda (WAF) e Cost Anomaly Detection com alertas orçamentários imediatos.

⚠️ **How CompTIA Tests This:** Trigger: "attacker drives up cloud costs" ou "service still works but bill is huge". Resposta: Economic Denial of Sustainability (EDoS) / Billing DoS.

### 📌 Fail Open vs. Fail Closed & Segredos no Cliente

🏠 **Real-World Analogy:** Se a catraca do banco ficar sem energia: "Fail Closed" tranca tudo e ninguém passa (prioriza segurança); "Fail Open" solta a trava e todo mundo entra (desastre em TI!). Chave de API embutida no aplicativo de celular é como colar a senha do cofre na capa externa do folheto de propaganda entregue na rua.

🔍 **Root Cause & Background:** Tratar chaves ou tokens incorporados no cliente como segredos, ou arquitetar APIs que respondem dados completos quando nenhum cabeçalho de autorização é enviado.

🛡️ **GRC Auditor Perspective:** Exigir autenticação do lado do servidor (Server-Side Authentication), mutual TLS ou tokens efêmeros; e adotar arquitetura de Negação por Padrão (Deny by Default / Fail Closed).

⚠️ **How CompTIA Tests This:** Trigger: "API returns data when Authorization header is omitted" -> Authentication bypass via Fail Open defect.

### 📌 Directory Traversal & Canonicalização

🏠 **Real-World Analogy:** O comando ../ é como dar um passo para trás no corredor para sair da sala de visitas e entrar no cofre da diretoria. Canonicalizar é passar o endereço a limpo para o nome formal e conferir se ele ainda está dentro do perímetro autorizado.

🔍 **Root Cause & Background:** Falta de validação e sanitização do caminho solicitado pelo usuário, permitindo sequências ../ para escapar da pasta web e ler arquivos do sistema operacional (ex: /etc/passwd).

🛡️ **GRC Auditor Perspective:** Validar caminhos canônicos contra allowlists de arquivos permitidos ou usar identificadores opacos indexados.

⚠️ **How CompTIA Tests This:** Trigger: "../etc/passwd" ou "attacker accesses files outside web root". Mitigação: Canonicalization + allowlist de arquivos.

## ⚡ QUICK-REFERENCE EXAM CHEAT SHEET

| Typical Exam Scenario / Practical Situation | Technical Concept & Target Answer |
|---|---|
| Vazamento público de dados em armazenamento na nuvem | **Cloud Misconfiguration (Bucket S3 público)** |
| Quem aplica o patch de segurança no Windows de uma VM na nuvem? | **O Cliente (Modelo de Responsabilidade Compartilhada em IaaS)** |
| Ferramenta que audita automaticamente configurações contra normas e CIS benchmarks | **CSPM (Cloud Security Posture Management)** |
| Fatura da nuvem veio estratosférica sem derrubar o serviço | **BDoS / EDoS (Economic Denial of Sustainability)** |
| Regra IAM com Action: "*" e Resource: "*" | **Violação do Menor Privilégio (Excessive Wildcard Permissions)** |
| Uso de ../ para escapar da pasta e ler arquivos do servidor | **Directory Traversal (resolvido via Canonicalization + Allowlist)** |

## ✅ Authentic Practice Questions (10 Real Exam Scenarios)

Scenario-based exam questions. Complete explanations and distractor analysis are provided in the answer key below.

QUESTION 1 · EXAM SCENARIO

**A mid-size e-commerce company runs its storefront on AWS with autoscaling groups, a CDN, and serverless functions. Over a holiday weekend, the monthly bill jumps from about $9,000 to more than $260,000. Monitoring shows no service outage, response times are normal, and the traffic comes from thousands of residential IPs repeatedly calling the most compute-intensive search and image-resize endpoints. The CEO wants to know what happened. Which cloud-specific attack best describes this event?**

**A)** A volumetric distributed denial of service that saturated the load balancer and took the store offline

**B)** An economic denial of sustainability attack in which the adversary drove consumption of metered resources to inflate the bill

**C)** A directory traversal attack that let the adversary read files outside the web root

**D)** A credential-stuffing campaign that compromised customer accounts and generated refunds

QUESTION 2 · EXAM SCENARIO

**A cloud engineer in a development account creates an object storage bucket for product images and applies a policy that grants read access to everyone so the marketing site can embed the images. Three weeks later, the security team receives an alert that the same bucket also holds nightly exports of customer invoices, and those objects are retrievable by anyone who has the URL. Which statement describes the root cause and the appropriate corrective action?**

**A)** The provider violated the shared responsibility model by failing to encrypt the bucket; the fix is to open a support ticket

**B)** The bucket policy/ACL was misconfigured, exposing data; the fix is to block public access, remove the public policy, scope access to specific principals, and add configuration monitoring

**C)** The bucket was compromised through directory traversal; the fix is to sanitize the URL parameter used by the marketing site

**D)** The objects were exposed through an authentication bypass in the storage API; the fix is to rotate the storage account keys

QUESTION 3 · EXAM SCENARIO

**A company migrates an internal application to infrastructure as a service. The provider supplies the hypervisor, storage, and network fabric; the company's team builds the virtual machines, installs the guest operating system, and manages the application. Six months later attackers exploit an unpatched kernel vulnerability in one of those guest operating systems and pivot to a database. Under the shared responsibility model, which party owns this failure?**

**A)** The cloud provider, because kernel vulnerabilities are part of the hypervisor it operates

**B)** The customer, because guest operating system patching is the customer's responsibility in infrastructure as a service

**C)** Both parties equally, because the model always splits every control 50/50

**D)** Neither party, because unpatched kernels are outside the scope of the shared responsibility model

QUESTION 4 · EXAM SCENARIO

**A SaaS provider's invoice download endpoint is implemented as a containerized Python service. A penetration tester submits a request with a file parameter containing repeated ../ sequences and receives the contents of /etc/passwd, a file well outside the intended invoice directory. The application runs as a non-root user in a container with a read-only host mount. Which control most directly prevents this class of attack?**

**A)** Enabling object versioning and lifecycle policies on the storage bucket that holds the invoices

**B)** Canonicalizing the requested path and validating it against an allowlist of permitted files or a fixed base directory before opening it

**C)** Enforcing multi-factor authentication for all users who download invoices

**D)** Increasing the container CPU and memory limits so requests time out before completing

**QUESTION 5 · EXAM SCENARIO**

**During an API review, a tester discovers that the endpoint GET /api/v2/internal/users returns the full user directory when the Authorization header is omitted entirely. When a valid but non-privileged token is supplied, the endpoint correctly returns 403. The code checks the token only inside the branch that handles privileged operations. Which vulnerability does this represent?**

**A)** An authentication bypass in which the authorization control fails open when credentials are absent

**B)** A directory traversal flaw caused by the URL path segment /internal

**C)** A billing denial of service caused by expensive directory queries

**D)** A cross-site scripting flaw in the JSON response returned to the client

**QUESTION 6 · EXAM SCENARIO**

**A security architect must give leadership continuous, automated visibility into misconfigured cloud resources across two providers and three accounts: publicly exposed storage, overly permissive identity policies, unencrypted volumes, and logging that has been switched off. The team wants findings prioritized against a benchmark and integrated into the existing ticketing workflow. Which capability best fits this requirement?**

**A)** A cloud security posture management tool that continuously assesses configurations against benchmarks and reports drift

**B)** A web application firewall placed in front of the public load balancers

**C)** A data loss prevention platform that inspects outbound email and file transfers

**D)** A host-based intrusion detection agent installed on each virtual machine

**QUESTION 7 · EXAM SCENARIO**

**An audit finds that the identity role used by the continuous integration pipeline has an attached policy with an Action of '*' and a Resource of '*' in the production account. The pipeline only needs to push container images to one registry and read one secrets path. Which change best reduces the risk?**

**A)** Rotate the pipeline's access keys every 30 days and keep storing them in the pipeline's environment variables

**B)** Require multi-factor authentication on the pipeline service account and shorten session duration

**C)** Replace the wildcard policy with least-privilege permissions limited to the specific registry actions and the single secrets path

**D)** Enable detailed logging on the pipeline role and review the logs monthly

**QUESTION 8 · EXAM SCENARIO**

**A cloud posture review of a healthcare company returns four findings in the production account. Which finding should be remediated first because it represents the greatest immediate risk of data exposure?**

**A)** An object storage bucket containing patient records has a policy granting read access to all principals

**B)** Object versioning is disabled on the bucket that stores patient records

**C)** Access logging for that bucket is forwarded to a log archive with a 90-day retention

**D)** The load balancer accepts TLS 1.2 in addition to TLS 1.3

**QUESTION 9 · EXAM SCENARIO**

**After an economic denial of sustainability incident in which attackers triggered thousands of expensive autoscaling events from a small number of source networks, a company wants controls that limit financial damage without breaking legitimate traffic peaks. Which combination is most appropriate?**

**A)** Resource quotas and maximum-size limits on autoscaling, per-client rate limiting at the edge, and cost anomaly detection with budget alerts

**B)** Disabling autoscaling and CDN caching so that resource use stays constant

**C)** Requiring MFA for all cloud console users and rotating root credentials

**D)** Enabling storage versioning and object lock on all buckets

**QUESTION 10 · EXAM SCENARIO**

**A mobile banking team ships an application that calls its own backend using an API key embedded in the compiled client binary and in the public JavaScript bundle. A researcher extracts the key and uses it to call the administrative endpoints of the same API, which accept the key as sufficient proof of identity. Which weakness was exploited?**

**A)** A directory traversal in the API gateway's static file handler

**B)** A cloud-specific authentication bypass caused by treating a client-side observable secret as an authenticator

**C)** An economic denial of sustainability attack that inflated API costs

**D)** A shared responsibility gap in which the provider failed to encrypt the API traffic

## ANSWER KEY & COMPREHENSIVE DISTRACTOR EXPLANATIONS

**Question 1: Option B — An economic denial of sustainability attack in which the adversary drove consumption of metered resources to inflate the bill**

The service stayed available and performance was normal, but metered cloud resources (compute, autoscaling instances, serverless invocations, egress) were consumed, inflating cost. That is an economic denial of sustainability (EDoS), sometimes called a billing or financial DoS: the attacker does not need to take the service down, only to make it expensive. Volumetric DDoS would degrade availability, directory traversal is a file-access flaw, and credential stuffing targets accounts, not cloud spend.

**Question 2: Option B — The bucket policy/ACL was misconfigured, exposing data; the fix is to block public access, remove the public policy, scope access to specific principals, and add configuration monitoring**

Public-read bucket policies and ACLs are the classic cloud misconfiguration. The customer controls data classification, bucket policy, ACLs, and public-access-block settings even when the provider manages the physical infrastructure, so responsibility lies with the customer. Correct remediation combines blocking public access, removing the permissive policy, granting least-privilege access to specific principals, and continuously detecting drift (for example with a CSPM tool).

**Question 3: Option B — The customer, because guest operating system patching is the customer's responsibility in infrastructure as a service**

In IaaS the provider secures the physical facilities, hardware, hypervisor, and network fabric, while the customer secures everything from the guest operating system upward: OS patching, hardening, accounts, application code, and data. The kernel vulnerability is therefore a customer control failure. The model is not a 50/50 split and it does not exclude patching.

**Question 4: Option B — Canonicalizing the requested path and validating it against an allowlist of permitted files or a fixed base directory before opening it**

This is directory traversal (path traversal): user-supplied input reaches the filesystem path without validation. The primary fix is to resolve the path to its canonical form, then confirm it stays inside the intended base directory, or better, reference files by an opaque identifier mapped to an allowlist. Versioning, MFA, and larger resource limits do not affect path handling.

**Question 5: Option A — An authentication bypass in which the authorization control fails open when credentials are absent**

The endpoint grants access when no credentials are presented, which is a fail-open authentication/authorization defect — a form of authentication bypass (broken access control). Secure designs deny by default and require a validated identity before any data is returned. Directory traversal, billing DoS, and XSS do not describe an authorization decision that defaults to 'allow'.

**Question 6: Option A — A cloud security posture management tool that continuously assesses configurations against benchmarks and reports drift**

Cloud security posture management (CSPM) continuously scans cloud accounts for misconfiguration and compliance drift — exactly the listed findings. A WAF protects against web-layer attacks, DLP focuses on data exfiltration, and host-based IDS monitors runtime activity on a single machine; none provides multi-account configuration assessment.

**Question 7: Option C — Replace the wildcard policy with least-privilege permissions limited to the specific registry actions and the single secrets path**

Excessive permissions are the finding; the fix is least privilege. A role with '*'/'*' can create, modify, or delete any resource in the account, so a compromised pipeline becomes full account takeover. Key rotation, MFA, and logging are useful defense-in-depth controls but do not remove an over-permissioned identity's blast radius.

**Question 8: Option A — An object storage bucket containing patient records has a policy granting read access to all principals**

A world-readable bucket containing regulated data is an active exposure — the public internet can retrieve the records now — and misconfiguration of this kind is the most common root cause of cloud data breaches. Versioning, log retention choices, and permitting TLS 1.2 are hardening concerns, not active exposures.

**Question 9: Option A — Resource quotas and maximum-size limits on autoscaling, per-client rate limiting at the edge, and cost anomaly detection with budget alerts**

Billing/economic denial of sustainability is fought with consumption governance: hard quotas and scaling caps, rate limiting and bot mitigation at the edge to blunt the attacker's leverage, and cost anomaly detection with budget alerts for early warning. Removing autoscaling harms legitimate availability, and MFA, key rotation, versioning, and object lock address identity and data integrity, not spend.

**Question 10: Option B — A cloud-specific authentication bypass caused by treating a client-side observable secret as an authenticator**

Secrets shipped to clients are observable by anyone and cannot serve as authentication. Because the API accepted that key alone as proof of identity, the attacker bypassed authentication and reached admin functions. The fix is server-side identity (tokens bound to a user, mutual TLS, or short-lived credentials) plus treating any leaked client secret as compromised. The other options describe different vulnerability classes.